RICHTLINIE FÜR DAS IT-RISIKOMANAGEMENT

ISMS-Dokument-Nr: RM-001 | Version: 3.0 | Status: Freigegeben | Vertraulich

§ 1 Methodik und Prozessablauf

Das Informationssicherheits-Risikomanagement (ISRM) ist ein essenzieller Bestandteil unseres nach ISO/IEC 27001 zertifizierten Managementsystems. Ziel ist es, Risiken für die Vertraulichkeit, Integrität und Verfügbarkeit von Unternehmenswerten (Assets) strukturiert zu identifizieren, zu bewerten und durch geeignete Maßnahmen auf ein akzeptables Maß zu reduzieren. Der Risikomanagement-Prozess erfolgt iterativ und muss für alle kritischen IT-Systeme mindestens einmal jährlich oder bei signifikanten Architekturänderungen durchgeführt werden. Er umfasst die Phasen Risikoidentifikation, Risikoanalyse, Risikobewertung sowie Risikobehandlung.

§ 2 Rollen und Verantwortlichkeiten

Die klare Zuweisung von Verantwortlichkeiten ist zwingend erforderlich, um sicherzustellen, dass erkannte Risiken nicht ignoriert werden. Es gelten folgende Rollenverteilungen:

- **Asset Owner (Werteverantwortlicher):** Der fachliche oder technische Verantwortliche für ein System oder einen Geschäftsprozess. Er ist verantwortlich für die Identifikation von Risiken und muss die vorgeschlagenen Behandlungsmaßnahmen budgetieren und freigeben.
- **Risk Owner (Risikoverantwortlicher):** Eine Person auf Management-Ebene, die die Rechenschaftspflicht für ein spezifisches Risiko trägt. Er entscheidet final, ob ein Restrisiko getragen wird.
- **CISO (Chief Information Security Officer):** Definiert die Methodik, moderiert die Risiko-Workshops, führt das zentrale Risikoregister und überwacht den Fortschritt der Risikominderungsmaßnahmen.

Hinweis zur Risikomeldung: Jeder Mitarbeiter ist verpflichtet, neu erkannte IT-Risiken (z.B. fehlende Backups, unsichere Passwörter bei Drittanbietern) umgehend per Ticket an das CISO-Office zu melden. Das CISO-Office bewertet die Meldung und trägt sie in das zentrale Risikoregister ein.

§ 3 Risikobewertungsmatrix (Risiko-Einstufung)

Die Bewertung eines Risikos erfolgt durch die Multiplikation von **Eintrittswahrscheinlichkeit** (Werte 1 bis 4) und der prognostizierten **Schadensauswirkung** (Werte 1 bis 4). Das Produkt ergibt den Risikowert (1 bis 16). Ab einem Risikowert von 8 gilt ein Risiko als nicht akzeptabel und erfordert sofortigen Handlungsbedarf.

Auswirkung → Wahrsch. ↓	1 - Gering (Kaum spürbar)	2 - Mittel (Störfaktor)	3 - Hoch (Geschäftskritisch)	4 - Kritisch (Existenzbedrohend)
4 - Sehr wahrscheinlich	4 (Moderat)	8 (Kritisch)	12 (Kritisch)	16 (Kritisch)
3 - Wahrscheinlich	3 (Gering)	6 (Moderat)	9 (Kritisch)	12 (Kritisch)
2 - Gelegentlich	2 (Gering)	4 (Moderat)	6 (Moderat)	8 (Kritisch)
1 - Unwahrscheinlich	1 (Gering)	2 (Gering)	3 (Gering)	4 (Moderat)

§ 4 Risikobehandlung und Akzeptanzkriterien

Für jedes identifizierte Risiko muss eine der vier Behandlungsoptionen (Vermeidung, Verminderung, Transferierung, Akzeptanz) gewählt werden. Risiken, die einen Risikowert von **8 oder höher** aufweisen (roter Bereich), dürfen auf keinen Fall ohne Umsetzung von mitigierenden Maßnahmen akzeptiert werden.

Werden Maßnahmen zur Risikominderung definiert, so ist diesen ein verbindliches Umsetzungsdatum und ein Verantwortlicher zuzuweisen. Ein **Risikoakzeptanz-Dokument (Sign-Off)** ist zwingend erforderlich für alle Restrisiken, die nach der Behandlung noch einen Wert von 4 oder höher aufweisen. Dieses Dokument muss vom jeweiligen Risk Owner sowie von der Geschäftsführung (bei Werten ab 6) handschriftlich oder mittels qualifizierter elektronischer Signatur unterzeichnet und dem CISO-Office übergeben werden.